

Authentication & Login Module

Engineering Specification for Claude Code

Phone + OTP Authentication • Email Verification • 5-Device Session Management

Millions-scale Architecture • Parents, Students, Teachers & Coaches

10M+

Target Users

5

Max Devices

6-Digit

OTP Security

4

User Roles

<200ms

API Response

React Native / Expo

FastAPI

PostgreSQL

Redis

JWT + Refresh Tokens

Twilio / MSG91

Table of Contents

1.	Executive Overview & Design Philosophy	3
2.	User Roles & Authentication Scope	4
3.	Functional Requirements	5
3		
·		
1	Phone Number + OTP Authentication	5
·		
3		
·		
2	Email Verification Flow	6
·		
3		
·		
3	Multi-Device Session Management (5-Device Limit)	7
·		
3		
·		
4	Role Detection & Post-Login Routing	8
·		
4.	UX / UI Specification	9
4		
·		
1	Screen Flow & Navigation Map	9
·		
4		
·		
2	Component-Level Design Tokens	10
·		
4		
·		
3	Micro-interactions & Delight Details	11
·		
5.	Technical Architecture	12
5		
·		
1	Mobile (React Native / Expo) File Structure	12
·		
5		
·		
2	Backend API Contracts (FastAPI)	13
·		

5		
.		1
3	Database Schema (PostgreSQL)	5
.		
5		
.		1
4	Caching & Rate Limiting (Redis)	7
.		
6.	Security Architecture	18
7.	Scale & Performance Engineering	20
8.	Third-Party Integrations	21
9.	Testing Requirements	22
10.	Phased Development Plan (Sprint-by-Sprint)	24
11.	Claude Code — Implementation Prompts	26
12.	Appendix: Error Codes & Compliance Notes	28

SECTION 01

Executive Overview & Design Philosophy

The Master-Kids Login Module is the first experience a parent, student, teacher, or coach has with the platform. It must communicate trust, simplicity, and professional quality in under 10 seconds. This document is the complete engineering specification — every screen, API, database table, security control, and deployment consideration required to build this module to production standard.

★ **Design North Star: A parent in Bangalore and a student in Jaipur should be able to log in with zero confusion, in under 30 seconds, on any device — the first time they try.**

Core Design Principles

One Entry Point for All

No role selection screen before login. All users (Parent, Student, Teacher, Coach) enter through the same beautiful, unified screen. Role is resolved server-side post-authentication.

Phone-First, India-Ready

Phone + OTP is the primary mechanism. No passwords. No usernames. Frictionless for a 9-year-old student and a 45-year-old parent alike.

Email as Safety Net

Email is a secondary, optional layer — for account recovery and high-trust operations. Users are gently nudged to add email post-login, never blocked.

Device Trust Model

Up to 5 trusted devices per account. Each device holds its own session token. Devices can be named, reviewed, and revoked — giving parents and teachers full control.

Scale Without Compromise

The architecture is designed for 10 million active users from day one. Every design decision — caching, rate limiting, token strategy — is made with this ceiling in mind.

First Impression = Brand

Loading states, transition animations, haptic feedback, and error messages all carry the Master-Kids brand. The login screen is not infrastructure — it's marketing.

Target SLAs at Scale

Metric	Target	Critical Threshold	Measurement
OTP Delivery Time	< 3 sec (p95)	5 sec	End-to-end SMS delivery
Login API Response	< 200ms (p99)	500ms	Server processing time

Metric	Target	Critical Threshold	Measurement
OTP Send Throughput	50,000 req/min	40,000 req/min	Peak (school start/end)
Auth Service Uptime	99.99%	99.95%	Monthly rolling window
Token Refresh Latency	< 50ms (p95)	200ms	Redis read + DB verify
Concurrent Logins	500,000/min	250,000/min	Simultaneous sessions

SECTION 02

User Roles & Authentication Scope

Master-Kids serves four distinct user types through a single, unified login interface. Role is never asked before or during login — it is resolved from the database after OTP verification. A user may hold multiple roles simultaneously (e.g., a teacher who is also a parent).

Role	DB Enum	Age Range	Primary Device	Session Priority	COPPA Trigger
Parent	PARENT	30–50	Smartphone	Dashboard	No
Student	STUDENT	5–14	Tablet / Shared	Habit Logger	Yes (under 13)
Teacher	TEACHER	22–45	Smartphone	Session Report	No
Coach	COACH	25–50	Smartphone	Progress View	No

Multi-Role Handling

A user's account can carry an array of roles: `roles TEXT[] DEFAULT '{}'`. If a returning user has more than one role, they are presented with a Role Switcher widget in the app header post-login — a clean dropdown allowing one-tap context switching without re-authentication. The active role drives the dashboard, navigation, and permissions shown.

■ **COPPA Compliance:** Any student identified as under 13 during onboarding must trigger a parent consent gate before account activation. The student's phone must be linked to a verified parent account. This is a legal requirement, not optional.

SECTION 03

Functional Requirements

3.1 Phone Number + OTP Authentication

The primary authentication mechanism. No passwords. No usernames. Just a phone number and a one-time code delivered by SMS. This approach removes the #1 drop-off point in user onboarding: forgotten passwords.

Parameter	Specification
OTP Length	6 digits, numeric only
OTP Validity Window	5 minutes from generation
Resend Cooldown	30 seconds between requests
Resend Attempts / Session	Maximum 3 attempts before 10-minute lockout
Failed OTP Attempts	Maximum 5 before 15-minute account lock
Rate Limit (per phone)	10 OTP requests per hour, Redis sliding window
OTP Storage	bcrypt hash in DB — never plaintext, never logged
SMS Provider Priority	MSG91 (primary, India) → Twilio (fallback, international)
Auto-Read (Android)	SMS Retriever API — OTP read without SMS permission
Clipboard Paste (iOS)	Prompt user to paste from clipboard on OTP screen focus
Country Code	Default: +91 (India). Searchable modal picker for international
Phone Validation	Regex + format validation client-side before API call
New User Handling	Phone not in DB → auto-register + route to onboarding
Enumeration Protection	Always return 'OTP sent' even for unregistered numbers

OTP State Machine

State	Trigger	Action	Next State
IDLE	App launch	Show phone entry screen	PHONE_ENTERED
PHONE_ENTERED	User taps Continue	Validate format → POST /auth/otp/send	OTP_SENDING
OTP_SENDING	API call in-flight	Show spinner, disable button	OTP_SENT
OTP_SENT	API success	Show OTP input, start 30s resend timer	OTP_VERIFYING

State	Trigger	Action	Next State
OTP_VERIFYING	6th digit entered	Auto-submit → POST /auth/otp/verify	VERIFIED / FAILED
VERIFIED	API returns tokens	Store tokens → role route	AUTHENTICATED
FAILED	Wrong OTP	Shake animation, attempt counter, inline error	OTP_SENT (retry)
LOCKED	5 failures / 3 resends	Lockout screen with countdown timer	IDLE (after timeout)

3.2 Email Verification Flow

Email is a secondary authentication layer introduced post-login. It serves as the account recovery mechanism and enables critical notifications for parents (progress alerts, teacher session reports). It must never block or complicate the primary phone+OTP flow.

Step 1 — Prompt

After first successful login, show a dismissible banner: 'Add email for account recovery'. Not a blocking modal. User can dismiss and proceed.

Step 2 — Email Entry

Dedicated EmailVerificationScreen. Single email input field, real-time format validation, 'Send Code' CTA.

Step 3 — OTP to Email

Backend generates 6-digit code (not a link — mobile-friendly). Sent via AWS SES. Code valid for 15 minutes.

Step 4 — Code Entry

Same 6-box OTP input component reused. Max 3 attempts. Resend available after 60 seconds.

Step 5 — Verified

Email verified badge stored. Confirmation animation. Banner permanently dismissed.

Recovery Path

Lost phone? User can initiate login via email: enter registered email → receive OTP to email → verify → select device to add.

Conflict Handling

If email already exists → 'This email is linked to another account. Use a different email.' Never reveal which account.

✓ Email verification uses the identical OTP input component from phone authentication. This reduces component count, ensures visual consistency, and halves the QA surface.

3.3 Multi-Device Session Management

Each user account supports up to 5 simultaneously active device sessions. A device is identified by a UUID generated at first app install and persisted in secure local storage. This model gives users the flexibility of multiple devices while preventing credential sharing at scale.

Parameter	Specification
Max Active Devices	5 per user account
Device Identification	UUID v4 generated on first install, stored in SecureStore (Expo)
Device Metadata	device_name (user-editable), os, app_version, last_active_at
Session Token	Per-device refresh token — not shared across devices
6th Device Attempt	Force Device Manager screen — user must revoke one to proceed
Inactive Auto-Revoke	Devices with no activity > 90 days are auto-deregistered
Manual Revoke	User can revoke any device from Settings → Devices
Revoke All	'Log out of all devices' option available; current device excluded
Token Invalidation	Revoked device's refresh token immediately blacklisted in Redis
Device Name Default	Auto-generated from OS + model: 'iPhone 15 (iOS 17.4)'
Security Notification	Push + email sent when a new device is added to account

3.4 Role Detection & Post-Login Routing

Scenario	Detection Logic	App Routes To
New user — phone not in DB	No record found in users table	OnboardingScreen → name, role, photo
Returning Parent	roles contains PARENT	/(parent)/dashboard
Returning Student	roles contains STUDENT	/(student)/home
Returning Teacher	roles contains TEACHER	/(teacher)/sessions
Returning Coach	roles contains COACH	/(coach)/dashboard
Multi-role user	roles array length > 1	Last active role dashboard + role switcher
Incomplete onboarding	onboarding_complete = false	Resume onboarding at last step

SECTION 04

UX / UI Specification

4.1 Screen Flow & Navigation Map

Every screen in the login module, its trigger condition, and its exit paths are defined below. No screen is optional in implementation — each handles a real user scenario at scale.

Screen	Entry Trigger	Key UI Elements	Exit To
SplashScreen	App cold start	Animated Master-Kids logo (Lottie). 1.5s. Auto-proceeds.	PhoneEntryScreen
PhoneEntryScreen	Post-splash / logout	Centered logo, large phone input, country picker, 'Continue' CTA, T&C; footnote.	OTPVerificationScreen
OTPVerificationScreen	OTP sent	6-box input, masked phone, resend timer, 'Change number' link.	Role Dashboard / DeviceManager
DeviceManagerScreen	6th device attempt	List of 5 devices with metadata. Revoke CTA per device.	OTPVerificationScreen (resume)
OnboardingScreen	New user detected	3-step: Name → Role Selection → Profile Photo (optional).	Role Dashboard
EmailVerificationScreen	Post-login prompt	Email input → 6-digit code → verified state.	Dismisses to dashboard
AccountLockedScreen	5 failed OTPs	Lockout message with countdown timer. No action available.	PhoneEntryScreen (timeout)
EmailLoginScreen	Lost phone recovery	Email input → OTP to email → device add flow.	Role Dashboard

4.2 Component-Level Design Tokens

Element	Token / Specification
Primary CTA Button	#6C63FF background, #FFFFFF text, 12px border-radius, 54px height, Helvetica-Bold 16px, 0 4px 12px rgba(108,99,255,0.4) shadow
OTP Digit Box	48×56px, 8px border-radius. Empty: 1.5px border #E2E8F0. Active: 2px border #6C63FF, #F5F3FF bg. Filled: #6C63FF bg, white text 24px bold
Phone Input Field	Full width, 54px height, 10px border-radius, 16px Helvetica, #1E293B text, 1px border #E2E8F0. Focus: 2px border #6C63FF
Country Code Picker	Flag emoji + dial code + chevron. Tappable. Opens searchable bottom sheet modal.
Error Text	#EF4444, 12px Helvetica, appears 4px below input with slide-in animation

Element	Token / Specification
Resend Timer	#94A3B8 greyed text when counting. #6C63FF bold when active. 'Resend OTP (28s)'
Device Card	White card, 12px radius, 12px shadow. Left: device icon. Center: name + OS + last seen. Right: 'Revoke' red text button
Typography — Primary	Nunito (Google Fonts). Fallback: Helvetica. Child-friendly rounded letterforms.
Typography — Secondary	Nunito Light for subtitles, Nunito ExtraBold for display numbers (OTP boxes)
Spacing Unit	8px base grid. Margins: 20px horizontal. Section gaps: 32px.
Dark Mode	Follows system preference. Dark BG: #0F172A. Surface: #1E293B. Text: #F1F5F9.
Animations	All transitions: 250ms ease-in-out. OTP error: 8px horizontal shake (3 cycles, 300ms).

4.3 Micro-interactions & Delight Details

- OTP boxes auto-advance focus on each digit entry — user never taps the next box
- Backspace on empty box auto-moves focus to previous box
- OTP auto-submits when 6th digit is entered — no submit button tap required
- Success: green checkmark replaces last OTP box, then smooth transition to next screen (350ms)
- Haptic feedback on: successful OTP verify (notificationSuccess), error (notificationError), each OTP digit (light impact)
- Phone number shown on OTP screen as masked: +91 XXXXX X1234 with a pencil icon to edit
- Loading spinner replaces CTA button text during API calls — button width unchanged (no layout shift)
- Splash screen uses Lottie animation of Master-Kids mascot — 1.5s, non-skippable
- Keyboard: numeric keyboard auto-raised on OTP screen, phone keyboard on phone entry screen
- Error messages slide in from below input (8px translate Y, 200ms), not modal alerts
- Country code picker opens as a bottom sheet with search bar — not a full-page modal
- All interactive elements have 44×44pt minimum touch targets (Apple HIG / WCAG compliance)

SECTION 05

Technical Architecture

5.1 Mobile File Structure (React Native / Expo)

src/
auth/
screens/
PhoneEntryScreen.tsx // Phone input + country picker
OTPVerificationScreen.tsx // 6-digit OTP input, auto-advance
EmailVerificationScreen.tsx // Email + 6-digit code flow
DeviceManagerScreen.tsx // List & revoke active devices
OnboardingScreen.tsx // Name, role, photo (3 steps)
AccountLockedScreen.tsx // Lockout countdown screen
EmailLoginScreen.tsx // Recovery via email
components/
OTPInput.tsx // Reusable 6-box animated input
CountryCodePicker.tsx // Bottom sheet, searchable, flags
DeviceCard.tsx // Device tile with revoke action
ResendTimer.tsx // Countdown + active resend CTA
PhoneInput.tsx // Formatted phone field
RoleSwitcher.tsx // Header dropdown for multi-role
hooks/
useOTPTimer.ts // 30s/60s countdown state
useDeviceId.ts // Generates/persists install UUID
useAuth.ts // Auth state + token management
store/
authStore.ts // Zustand: user, tokens, deviceId, roles
services/
authService.ts // All API calls (typed, abstracted)
tokenService.ts // JWT decode, expiry check, refresh
deviceService.ts // Device fingerprint + metadata
constants/
authColors.ts // Brand tokens
authErrors.ts // Error code → user message map

5.2 Backend API Contracts (FastAPI)

All endpoints follow REST conventions. Every response includes a request_id for distributed tracing. All timestamps are UTC ISO-8601.

POST /auth/otp/send — Send OTP to phone

```
Body: { "phone": "+919876543210", "country_code": "+91" }  
Returns: { "request_id": "uuid", "expires_at": "ISO-8601", "resend_available_at": "ISO-8601"  
}  
Rate limit: 10/hr per phone. Returns 200 even if phone unregistered (enumeration protection).
```

POST /auth/otp/verify — Verify OTP + issue tokens

```
Body: { "phone": "+919876543210", "otp": "847291", "request_id": "uuid", "device_id": "uuid",  
"device_meta": { "name": "Ani iPhone 15", "os": "iOS 17.4", "app_version": "1.0.0" } }  
Returns: { "access_token": "JWT", "refresh_token": "uuid", "user": { "id": "uuid", "roles":  
["PARENT"], "is_new": false, "onboarding_complete": true } }
```

POST /auth/token/refresh — Rotate refresh token

```
Body: { "refresh_token": "uuid", "device_id": "uuid" }  
Returns: { "access_token": "JWT", "refresh_token": "uuid" }  
Invalidates old refresh token immediately (rotation).
```

POST /auth/logout — Revoke current device session

```
Headers: Authorization: Bearer {access_token}  
Body: { "device_id": "uuid" }  
Returns: { "success": true }
```

GET /auth/devices — List all active device sessions

```
Headers: Authorization: Bearer {access_token}  
Returns: [ { "device_id": "uuid", "name": "string", "os": "string", "last_active":  
"ISO-8601", "is_current": true } ]
```

DELETE /auth/devices/{device_id} — Revoke a specific device

```
Headers: Authorization: Bearer {access_token}  
Action: Blacklists device refresh token, removes session record.
```

DELETE /auth/devices — Revoke all devices except current

```
Headers: Authorization: Bearer {access_token}  
Action: Mass session revocation. Current device session preserved.
```

POST /auth/email/send-verification — Send email OTP

```
Headers: Authorization: Bearer {access_token}
Body: { "email": "user@example.com" }
Returns: { "request_id": "uuid", "expires_at": "ISO-8601" }
```

POST /auth/email/verify — Verify email OTP

```
Headers: Authorization: Bearer {access_token}
Body: { "email": "user@example.com", "code": "847291" }
Action: Sets email_verified = true on user record.
```

Standard Error Response Format

```
{
  "error": {
    "code": "OTP_EXPIRED", // Machine-readable
    "message": "OTP has expired", // Human-readable
    "request_id": "uuid", // Trace ID
    "retry_after": 300 // Seconds (if applicable)
  }
}
```

Error Code	HTTP	Description
OTP_EXPIRED	429	OTP validity window (5 min) has passed
OTP_INVALID	400	OTP digits don't match
OTP_MAX_ATTEMPTS	429	5 failed attempts — account locked
RESEND_COOLDOWN	429	30s cooldown not yet elapsed
RATE_LIMITED	429	10 OTPs/hr limit hit — retry_after provided
DEVICE_LIMIT_EXCEEDED	409	6th device — DeviceManager required
TOKEN_EXPIRED	401	Access token expired — refresh required
TOKEN_REVOKED	401	Refresh token revoked (device removed)
PHONE_INVALID	400	Phone number format validation failed
EMAIL_EXISTS	409	Email linked to another account
EMAIL_CODE_EXPIRED	429	Email verification code expired

5.3 Database Schema (PostgreSQL)

All tables use UUID primary keys. Row Level Security (RLS) enabled on all user-facing tables. Indexes are defined for every high-frequency query path.

users — Core User Record

```
CREATE TABLE users (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  phone VARCHAR(15) UNIQUE NOT NULL,
  country_code VARCHAR(5) NOT NULL DEFAULT '+91',
  email VARCHAR(255) UNIQUE,
  email_verified BOOLEAN DEFAULT FALSE,
  name VARCHAR(100),
  avatar_url TEXT,
  roles TEXT[] DEFAULT '{}', -- PARENT/STUDENT/TEACHER/COACH
  active_role TEXT, -- last used role
  onboarding_complete BOOLEAN DEFAULT FALSE,
  is_active BOOLEAN DEFAULT TRUE,
  locked_until TIMESTAMPTZ, -- temporary lockout
  dpdp_consent_at TIMESTAMPTZ, -- compliance timestamp
  coppa_parent_id UUID REFERENCES users(id), -- for under-13
  created_at TIMESTAMPTZ DEFAULT NOW(),
  updated_at TIMESTAMPTZ DEFAULT NOW()
);
CREATE INDEX idx_users_phone ON users(phone);
CREATE INDEX idx_users_email ON users(email) WHERE email IS NOT NULL;
```

otp_requests — Short-lived, Auto-purged

```
CREATE TABLE otp_requests (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  phone VARCHAR(15) NOT NULL,
  otp_hash VARCHAR(255) NOT NULL, -- bcrypt(otp, 10)
  attempts INT DEFAULT 0,
  expires_at TIMESTAMPTZ NOT NULL,
  used BOOLEAN DEFAULT FALSE,
  created_at TIMESTAMPTZ DEFAULT NOW()
);
CREATE INDEX idx_otp_phone ON otp_requests(phone, expires_at);
-- Cleanup job: DELETE FROM otp_requests WHERE expires_at < NOW() - INTERVAL '1 hour';
```

device_sessions — Per-device JWT Sessions

```
CREATE TABLE device_sessions (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  user_id UUID REFERENCES users(id) ON DELETE CASCADE,
```

```

device_id VARCHAR(255) NOT NULL, -- UUID from app install
device_name VARCHAR(100), -- 'Ani iPhone 15'
os VARCHAR(50), -- 'iOS 17.4'
app_version VARCHAR(20),
refresh_token_hash VARCHAR(255) NOT NULL, -- bcrypt(refresh_token)
is_active BOOLEAN DEFAULT TRUE,
last_active_at TIMESTAMPTZ DEFAULT NOW(),
created_at TIMESTAMPTZ DEFAULT NOW(),
UNIQUE(user_id, device_id)
);
CREATE INDEX idx_sessions_user ON device_sessions(user_id) WHERE is_active = TRUE;

```

email_verification_codes

```

CREATE TABLE email_verification_codes (
id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
user_id UUID REFERENCES users(id) ON DELETE CASCADE,
email VARCHAR(255) NOT NULL,
code_hash VARCHAR(255) NOT NULL, -- bcrypt(code)
attempts INT DEFAULT 0,
expires_at TIMESTAMPTZ NOT NULL,
used BOOLEAN DEFAULT FALSE,
created_at TIMESTAMPTZ DEFAULT NOW()
);

```

auth_audit_log — Immutable Event Log

```

CREATE TABLE auth_audit_log (
id BIGSERIAL PRIMARY KEY,
user_id UUID, -- nullable (pre-registration events)
event_type VARCHAR(50), -- OTP_SENT | OTP_VERIFIED | LOGIN |
-- LOGOUT | DEVICE_ADDED | DEVICE_REVOKED |
-- EMAIL_VERIFIED | ACCOUNT_LOCKED
device_id VARCHAR(255),
ip_address INET,
user_agent TEXT,
metadata JSONB, -- event-specific data
created_at TIMESTAMPTZ DEFAULT NOW()
);
CREATE INDEX idx_audit_user ON auth_audit_log(user_id, created_at DESC);
-- This table is append-only. No UPDATE or DELETE. Use partitioning at 100M rows.

```

5.4 Caching & Rate Limiting (Redis)

Key Pattern	TTL	Type	Purpose
rate:otp:{phone}	3600s	Counter	OTP request rate limit (10/hr)
rate:verify:{phone}	900s	Counter	OTP failure rate limit (5 max)
session:{user_id}	30 days	Set	Active device_id set for user
blacklist:token:{jti}	15m	String	Revoked access token JTI blacklist
lock:account:{phone}	900s	String	Account lockout (15 min)
otp:pending:{request_id}	300s	Hash	In-flight OTP session metadata
resend:cooldown:{phone}	30s	String	Resend cooldown enforcement

■ **Redis Cluster Configuration:** Minimum 3-node Redis Cluster with AOF persistence enabled. Use Redis Sentinel for automatic failover. Target: 99.99% availability for rate limiting keys.

SECTION 06

Security Architecture

■ All security requirements in this section are **NON-NEGOTIABLE** for beta release. Zero exceptions. Any deviation requires a written sign-off from the security lead.

Token Architecture

- Access Token: JWT, RS256 signed, 15-minute TTL. Payload: { sub: user_id, roles, device_id, jti }
- Refresh Token: Opaque UUID v4, bcrypt-hashed in DB, bound to device_id. 30-day TTL.
- Token Rotation: Every refresh call invalidates the old token and issues a new one. Prevents replay attacks.
- Token Revocation: Revoked JTIs stored in Redis blacklist for 15 minutes (access token max lifetime).
- Storage: Access token in memory only (authStore). Refresh token in SecureStore (Expo) — never AsyncStorage.

OTP Security

- OTPs stored as bcrypt(otp, cost=10) in otp_requests table. Never stored in plaintext.
- OTPs never appear in application logs, error messages, or analytics events.
- Timing-safe comparison for OTP verification (prevents timing attacks).
- OTP generation uses crypto.randomInt() — not Math.random().
- Dead OTP records purged hourly — no long-term OTP data retained.

Transport & Infrastructure

- All API traffic over HTTPS with TLS 1.3 minimum. No HTTP endpoints exposed.
- Certificate pinning on mobile app for auth endpoints.
- All auth endpoints behind WAF (AWS WAF / Cloudflare) with OWASP Core Rule Set.
- DDoS protection via Cloudflare (rate limiting at edge, before hitting origin).
- HSTS headers enforced on all API responses. Strict-Transport-Security: max-age=31536000.

Data Protection

- Phone numbers masked in all logs: +91 XXXXX X1234.
- Device metadata encrypted at rest (AES-256) in DB.
- Refresh tokens never appear in server logs.
- PII excluded from analytics events (Mixpanel, Sentry).
- DPDP Act (India) compliance: consent timestamp stored for every user.

Abuse Prevention

- Phone enumeration protection: always return 'OTP sent' even for unregistered numbers.
- Bot protection: invisible reCAPTCHA on OTP send endpoint for non-organic traffic patterns.

- Geo-velocity check: flag if same account logs in from 2 geographically distant IPs within 10 minutes.
- Anomaly detection: >100 login attempts/min from single IP → auto-block + alert.
- OTP brute force: 5 failed attempts → 15-minute account lock. Not IP-based (VPN evasion).

Pre-Beta Security Checklist

Requirement	Priority	Status
OTP stored as bcrypt hash — never plaintext	P0	[] Pending
Refresh tokens bound to device_id — cross-device reuse impossible	P0	[] Pending
Rate limiting active on OTP send + verify endpoints	P0	[] Pending
Token blacklist (Redis) operational for revoked sessions	P0	[] Pending
HTTPS enforced on all endpoints — no HTTP fallback	P0	[] Pending
Phone numbers masked in all log outputs	P0	[] Pending
SecureStore (not AsyncStorage) used for refresh token	P0	[] Pending
OTP never logged anywhere in the system	P0	[] Pending
COPPA consent gate live for under-13 student accounts	P1	[] Pending
DPDP consent timestamp stored on user record	P1	[] Pending
Geo-velocity anomaly detection configured	P1	[] Pending
reCAPTCHA integrated on OTP send endpoint	P1	[] Pending
Certificate pinning enabled in production builds	P1	[] Pending
WAF rules reviewed and active	P1	[] Pending
Penetration test completed against OWASP Mobile Top 10	P1	[] Pending

SECTION 07

Scale & Performance Engineering

The login module is the most latency-sensitive surface of the entire platform. A slow login creates doubt. Every architecture decision below is justified by the 10M user target.

Stateless Auth Service

- FastAPI auth service is fully stateless — all session state lives in Redis and PostgreSQL.
- Horizontal scaling: add instances behind AWS ALB / nginx with zero-downtime. No sticky sessions.
- Target: 20 auth service pods in Kubernetes, auto-scaling on CPU > 60% and RPS > 2000/pod.
- Health check endpoint: GET /health returns 200 in < 10ms. Readiness probe: checks Redis + DB connections.

Database Performance at Scale

- Primary DB: PostgreSQL with read replicas (1 primary, 3 read replicas in production).
- users and device_sessions tables: partitioned by created_at (monthly) beyond 50M rows.
- auth_audit_log: partitioned by month from day one. Retain 12 months hot, archive to S3 beyond.
- Connection pooling: PgBouncer in transaction mode. Max 1000 connections to DB; 10,000 app connections.
- otp_requests: purged hourly via pg_cron. Table never grows beyond ~10,000 rows.

Redis Architecture

- Redis Cluster: 3 primary + 3 replica shards. Rate limiting keys distributed by hash slot.
- Redis 7.x with LFU eviction for blacklist keys. Max memory: 8GB per node.
- Lua scripts for atomic rate limit operations — prevents race conditions under load.
- Redis Sentinel for failover: < 30s automatic promotion. Auth service reconnects via retry logic.

SMS Delivery at Peak

- Peak load: school start (8–9 AM) and end (4–5 PM) — up to 50,000 OTPs/minute expected.
- SMS provider abstraction layer: primary (MSG91) → fallback (Twilio). Switch < 5s if primary degrades.
- MSG91 rate: pre-negotiate 100,000 SMS/min capacity. Twilio as backup at 50,000/min.
- Async OTP send: API returns immediately (request_id) while SMS dispatched via Celery/Redis Queue.
- DLT (Distributed Ledger Technology) registration mandatory for India transactional SMS.

CDN & Edge Optimization

- API behind Cloudflare. Edge caching for static assets (app JS bundles, fonts).
- Cloudflare Workers for OTP rate limiting at edge — blocks before traffic hits origin.
- API response compression: gzip/brotli on all JSON responses.
- Keep-Alive connections: auth service maintains persistent connections to Redis and DB.

SECTION 08

Third-Party Integrations

Integration	Provider	Fallback	Purpose	Notes
SMS OTP (India)	MSG91 / Kaleyra	Twilio	Deliver 6-digit OTP	DLT registration required
SMS OTP (International)	Twilio	AWS SNS	International users	Country-aware routing
Email Delivery	AWS SES	SendGrid	Email OTP, notifications	Verified domain required
Push Notifications	Firebase FCM	—	New device alerts	Via Expo Push API
Analytics	Mixpanel	Amplitude	Auth funnel tracking	No PII in events
Error Tracking	Sentry	—	Crash + error reporting	PII scrubbing enabled
Feature Flags	LaunchDarkly	Firebase RC	Gradual rollout	Beta user targeting
Bot Protection	Google reCAPTCHA v3	hCaptcha	OTP send protection	Invisible, score-based
Secret Management	AWS Secrets Manager	HashiCorp Vault	API keys, DB credentials	Rotate every 90 days

Analytics Events to Track (Auth Funnel)

Event Name	When Fired
auth_screen_viewed	Phone entry screen rendered
phone_submitted	User tapped Continue with valid number
otp_sent	OTP API call succeeded
otp_screen_viewed	OTP input screen rendered
otp_resend_tapped	Resend OTP triggered
otp_verified_success	OTP correct — tokens issued
otp_verified_failure	OTP wrong — attempt incremented
device_limit_hit	6th device attempted — DeviceManager shown

Event Name	When Fired
device_revoked	User removed a device
login_complete	User reached role dashboard
email_prompt_shown	Post-login email nudge displayed
email_verified	Email verification completed
onboarding_started	New user hit onboarding flow
onboarding_completed	All onboarding steps done

SECTION 09

Testing Requirements

No code from this module ships to beta without passing all tests in this section. Test coverage is a hard gate, not a soft target.

Test Type	Coverage Target	Framework	Gate
Unit Tests — Auth Logic	100%	Jest	CI block
Unit Tests — API Routes	95%	pytest	CI block
Integration Tests — API	90%	Supertest / pytest	CI block
E2E — Happy Paths	100% of flows	Detox (mobile)	CI block
E2E — Error Paths	All error states	Detox (mobile)	CI block
Load Test — OTP Send	50,000 req/min	k6	Beta gate
Load Test — Token Refresh	500,000/min concurrent	k6	Beta gate
Security Pentest	OWASP Mobile Top 10	OWASP ZAP + manual	Beta gate
Accessibility	WCAG 2.1 AA	axe + screen reader	Beta gate

Critical Test Scenarios

ID	Scenario	Steps	Expected Result
TC-001	Happy Path — New User	Enter valid phone → receive OTP → enter OTP → onboarding starts	Onboarding screen rendered
TC-002	Happy Path — Returning Parent	Enter registered parent phone → OTP → verify	Parent dashboard rendered
TC-003	Happy Path — Student (shared device)	Enter student phone → OTP → verify	Student home rendered
TC-004	Wrong OTP — 3 Attempts	Enter OTP incorrectly 3 times in a row	Correct error state shown each time, no lockout at 3
TC-005	Wrong OTP — 5 Attempts (Lockout)	Enter OTP incorrectly 5 times	Account locked, lockout screen with countdown shown
TC-006	Expired OTP	Wait 5+ minutes then enter OTP	OTP_EXPIRED error, resend prompt shown

ID	Scenario	Steps	Expected Result
TC-007	Resend Cooldown	Tap Resend immediately after OTP sent	Button disabled for 30s, countdown visible
TC-008	6th Device Login	Log in on 6th device with active 5 sessions	Device Manager screen shown, login blocked
TC-009	Revoke Device + Login	Revoke device in Device Manager → proceed	Login completes on new device
TC-010	Email Verification — Success	Post-login: add email → receive code → enter code	Email verified badge shown
TC-011	Email Already Exists	Add email that belongs to another account	Conflict error shown, no account info leaked
TC-012	Token Refresh	Let access token expire, perform authenticated action	Transparent refresh, no logout
TC-013	Revoked Session Access	Revoke device, try authenticated call with old token	401 returned, app redirects to login
TC-014	Rate Limit — OTP Send	Send >10 OTP requests in 1 hour	11th request returns RATE_LIMITED
TC-015	Multi-Role Routing	Login with account having PARENT + TEACHER roles	Role Switcher displayed in header
TC-016	COPPA — Under-13 Student	Register student DOB < 13 years	Parent consent gate triggered

SECTION 10

Phased Development Plan

Sprint	Timeline	Deliverables	Priority
Sprint 1	Week 1–2	- PhoneEntryScreen with country code picker - OTPVerificationScreen (6-box component) - POST /auth/otp/send API + SMS integration (MSG91) - POST /auth/otp/verify API + JWT issuance - Zustand authStore with token persistence (SecureStore) - Device session creation in DB - Basic rate limiting (Redis)	P0 — Critical
Sprint 2	Week 3	- Device limit enforcement (5-device check on login) - DeviceManagerScreen — list + revoke devices - DELETE /auth/devices/{id} API - Token rotation on refresh - Redis blacklist for revoked tokens - Security notification push on new device add	P0 — Critical
Sprint 3	Week 4	- EmailVerificationScreen (reuse OTPInput component) - POST /auth/email/send-verification API - POST /auth/email/verify API - Post-login email nudge banner (dismissible) - Email conflict handling - Email-based recovery login flow (EmailLoginScreen)	P1 — High
Sprint 4	Week 5	- OnboardingScreen (3-step: Name → Role → Photo) - Role Switcher component for multi-role users - Multi-role routing logic (last active role) - Incomplete onboarding resumption - AccountLockedScreen with countdown - COPPA consent gate for under-13 students	P1 — High
Sprint 5	Week 6	- Auto-SMS read via Android SMS Retriever API - iOS clipboard paste prompt for OTP - Haptic feedback integration (Expo Haptics) - Dark mode support (system preference) - Lottie splash screen animation - Micro-interaction polish (shake, transitions, auto-advance) - Nunito font integration and design token audit	P1 — High
Sprint 6	Week 7	- Mixpanel auth funnel event instrumentation - Sentry error tracking setup (PII scrubbing) - LaunchDarkly feature flag integration - reCAPTCHA v3 on OTP send endpoint - Accessibility audit (WCAG 2.1 AA) - DPDP consent recording	P2 — Medium

Sprint	Timeline	Deliverables	Priority
Sprint 7	Week 8	- Full E2E test suite (Detox) — all 16 test scenarios - Unit tests reaching 100% coverage on auth logic - Integration test suite for all API endpoints - k6 load test: 50,000 OTP/min, 500,000 refresh/min - OWASP ZAP security scan + manual pentest - All P0 security checklist items verified	P0 — Critical
Sprint 8	Week 9	- Beta environment provisioning (AWS ECS/EKS) - Redis Cluster setup with Sentinel - PostgreSQL read replicas configured - PgBouncer connection pooling - Cloudflare WAF rules activated - Monitoring dashboards (Datadog/Grafana) live - Runbook documented for on-call team	P1 — High

■ Total timeline: 9 weeks to beta-ready. Sprint 7 (testing) is a hard gate — no beta release without passing all test scenarios. Buffer 1 week before beta launch for critical bug fixes.

SECTION 11

Claude Code — Implementation Prompts

Use these prompts verbatim when starting each sprint in VS Code / Claude Code. Always reference this specification document. Always start a new session with the context primer.

Context Primer (start every session with this)

We are building the Login Module for Master-Kids – a three-sided platform for Parents, Students, Teachers and Coaches. Read CLAUDE.md. The login module specification is at [path to this PDF / spec doc]. This module uses React Native + Expo (mobile), FastAPI (backend), PostgreSQL (DB), and Redis (caching/rate limiting). Phone + OTP is the primary auth. 5-device limit per account. JWT + refresh tokens. All tokens stored in SecureStore. Design system: Nunito font, #6C63FF primary, 8px grid.

Sprint 1 — Core OTP Flow

Build Sprint 1 of the Master-Kids Login Module.

Create the following in order:

1. PhoneEntryScreen.tsx – full-width phone input, +91 default country code, 'Continue' CTA disabled until valid 10-digit number, T&C; footnote.
2. OTPVerificationScreen.tsx – 6 individual digit boxes, auto-advance, auto-submit on 6th digit, resend timer (30s), masked phone display.
3. OTPInput.tsx – reusable component, handles auto-advance, backspace, paste.
4. authService.ts – typed functions: sendOTP(phone), verifyOTP(phone, otp, requestId, deviceMeta). Returns typed response objects.
5. authStore.ts (Zustand) – user, accessToken, refreshToken, deviceId state. RefreshToken persisted to SecureStore.
6. useDeviceId.ts – generates UUID on first install, persists to SecureStore.
7. FastAPI: POST /auth/otp/send and POST /auth/otp/verify endpoints.
8. PostgreSQL migrations for users, otp_requests, device_sessions tables.
9. Redis rate limiting: 10 OTP sends/hr, 5 verify fails before lock.

Follow the exact API contracts in the spec. Use bcrypt for OTP hashing.

Sprint 2 — Device Management

Build Sprint 2 of the Master-Kids Login Module.

1. Add device count check to POST /auth/otp/verify – if user has 5 active device sessions, return DEVICE_LIMIT_EXCEEDED (409) with device list.
2. DeviceManagerScreen.tsx – list of up to 5 DeviceCard components, each showing device name, OS, last active timestamp, Revoke button. 'Continue' button active after at least one device is revoked.
3. DeviceCard.tsx – reusable component with revoke confirmation.

4. FastAPI: GET /auth/devices, DELETE /auth/devices/{id}, DELETE /auth/devices.
5. Token rotation: every POST /auth/token/refresh must invalidate old token and issue new one. Blacklist old JTI in Redis for 15 minutes.
6. Security push notification via FCM when new device is added to account.

Sprint 3 — Email Verification

Build Sprint 3 of the Master-Kids Login Module.

1. EmailVerificationScreen.tsx – email input with real-time format validation, 'Send Code' CTA, then transitions to 6-digit code entry (reuse OTPInput). Success state: animated checkmark, 'Email verified' message.
2. Post-login email nudge banner – dismissible, shown once after first login, stored in AsyncStorage so it doesn't repeat.
3. FastAPI: POST /auth/email/send-verification, POST /auth/email/verify.
4. PostgreSQL: email_verification_codes table migration.
5. EmailLoginScreen.tsx – recovery path: email input → OTP to email → device add.
6. Handle EMAIL_EXISTS conflict error gracefully (no account info leak).

Sprint 5 — Polish & Micro-interactions

Build Sprint 5 polish for the Master-Kids Login Module.

1. Android SMS Retriever API – auto-read OTP, fill boxes without user action.
2. iOS clipboard paste – prompt appears when OTP screen focused, auto-fills.
3. Haptic feedback using Expo Haptics:
 - Each OTP digit entry: `impactAsync(ImpactFeedbackStyle.Light)`
 - OTP success: `notificationAsync(NotificationFeedbackType.Success)`
 - OTP error: `notificationAsync(NotificationFeedbackType.Error)`
4. Dark mode: `useColorScheme()` hook, all screens use theme tokens.
5. OTP error animation: horizontal shake (`translateX: 0→8→-8→0, 300ms, 3x`).
6. Transition on OTP success: green fill animation on boxes → 350ms screen slide.
7. Lottie splash animation – `masterkids-splash.json`, 1.5s, then navigate.
8. Load Nunito from Google Fonts via `expo-font`. Apply globally.

APPENDIX

Appendix: Error Codes, Compliance & Glossary

Complete Error Code Reference

Code	HTTP	Cause	User Action	Dev Note
OTP_EXPIRED	400	5 min window elapsed	Resend OTP	Show resend button immediately
OTP_INVALID	400	Digits don't match	Re-enter OTP	Increment attempt counter
OTP_MAX_ATTEMPTS	429	5 failures hit	Wait 15 minutes	Show lockout screen
RESEND_COOLDOWN	429	30s not elapsed	Wait for timer	Show remaining seconds
RATE_LIMITED	429	10/hr limit hit	Try in 1 hour	Show retry_after in response
DEVICE_LIMIT_EXCEEDED	409	6th device attempt	Remove a device	Return device list
TOKEN_EXPIRED	401	15 min access TTL elapsed	Auto-refresh	Client refreshes silently
TOKEN_REVOKED	401	Device revoked	Re-login	Redirect to PhoneEntry
TOKEN_INVALID	401	Malformed JWT	Re-login	Log security event
PHONE_INVALID	400	Format validation fail	Correct number	Client-side first
EMAIL_EXISTS	409	Email on another account	Use different email	No info leaked
EMAIL_CODE_EXPIRED	429	15 min elapsed	Resend code	—
ACCOUNT_LOCKED	423	15 min lockout active	Wait for timeout	Return locked_until timestamp
SERVICE_UNAVAILABLE	503	SMS provider down	Retry	Failover to backup provider

Compliance Requirements

DPDP Act (India)

Digital Personal Data Protection Act 2023. Record consent timestamp (dpdp_consent_at) on all user records. Show consent notice on first login. Provide data deletion endpoint.

COPPA (USA)

Children's Online Privacy Protection Act. For any student under 13: collect parental consent before account activation. Link student account to parent. Restrict data collection to minimum necessary.

GDPR (EU/International)

For international users: explicit consent, right to deletion, data portability. Ensure EU user data stored in EU region if applicable.

IT Act 2000 (India)

Sensitive personal data (phone number, email) must be protected with reasonable security practices. Encrypt at rest and in transit.

DLT Registration

All transactional SMS sent in India must originate from a DLT-registered sender ID. Register template: 'Your Master-Kids OTP is {otp}. Valid for 5 minutes. Do not share.'

App Store / Play Store

Apple and Google require disclosure of authentication data collection in privacy labels/data safety forms. Update before submission.

Glossary

Term	Definition
JWT	JSON Web Token. Access credential containing user ID, roles, device ID, and expiry.
OTP	One-Time Password. 6-digit code sent via SMS or email for authentication.
Refresh Token	Opaque long-lived token used to obtain new access tokens. Bound to device.
bcrypt	Password hashing function used to hash OTP codes and refresh tokens before DB storage.
SecureStore	Expo's encrypted on-device storage — equivalent to iOS Keychain / Android Keystore.
DLT	Distributed Ledger Technology — India's regulatory requirement for SMS sender registration.
DPDP	Digital Personal Data Protection Act, 2023 — India's primary data privacy law.
Device Fingerprint	UUID generated at first app install, unique to device + app installation.
Token Rotation	Practice of issuing a new refresh token on every use and invalidating the old one.
JTI	JWT ID — unique identifier per token, used for revocation blacklisting.